

# Executive Access Bugs and Edge Cases Report

QA audit date: 2026-07-29 | Important bugs and edge cases only | No code changed

| Module        | Severity | Main bug                                                                                                                                      | Important edge case                                                        | Best solution                                                                                 |
|---------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------|
| Dashboard     | Medium   | Follow-up widgets can show records where Executive is follow-up owner but cannot open the prospect.                                           | Follow-up assigned separately, midnight boundary, deleted lead.            | Include follow-up ownership in prospect access or hide inaccessible follow-ups.               |
| Notifications | Medium   | Notifications can link to Customers or Settings pages Executive cannot open. Stale links can remain after reassignment/delete.                | Lead reassigned away, deleted prospect, settings/customer link.            | Generate links by role permission and handle stale records clearly.                           |
| Leads         | High     | Product interest item needs stronger org validation. Failed uploads can orphan files. Unauthorized filters return empty instead of clear 403. | Create with another assignee, cross-org item ID, double convert.           | Validate item IDs by org, clean failed uploads, return 403 for explicit unauthorized filters. |
| Prospects     | High     | Executive can be assigned a follow-up but fail to open prospect if not prospect owner. Follow-up metadata can drift.                          | Follow-up assigned separately, past date, terminal won/lost.               | Align prospect access with follow-up ownership and keep one follow-up source of truth.        |
| Quotations    | High     | Executive can link quotation to any same-org prospect if prospect ID is known. Rejected quote edit rule is unclear.                           | Link to another user's prospect, edit rejected quote, invalid item totals. | Validate prospect ownership before linking quotation and define rejected-edit rules.          |
| Customers     | Medium   | Customers page is blocked for Executive, but APIs can return Executive-scoped won prospects.                                                  | Direct /customers URL, direct API call, won prospect, approved quote only. | Decide if Executive gets Customers; enable scoped route or restrict/clarify APIs.             |
| Reports       | High     | Reports compute all tabs per request. Limit has no max. CSV export can return 10000 rows without audit.                                       | Large date range, export own report, invalid dates, no data.               | Compute requested tab only, cap limits, validate dates, audit exports.                        |
| Profile       | High     | Password change is hidden in UI but direct route/API still works. Backend can accept crafted organization asset upload.                       | Open change-password URL, crafted asset upload, invalid image.             | Enforce password and asset permissions in backend and hide inaccessible routes.               |
| Settings      | Medium   | Settings is listed for Executive but route/sidebar block it.                                                                                  | Direct /settings URL, settings notification, mobile access denied.         | Add limited Executive settings or remove from module list/help.                               |
| Help          | Low      | Executive help mentions outdated statuses and misses customer access/follow-up ownership rules.                                               | Search lead status, customers, quotation approval, no results.             | Update FAQs to match current statuses, routes, and permissions.                               |